



Cybersecurity in Age of AI

Black Hat 2024's top 3 LLM security risks

Jayesh Shinde | jayesh@digit.in

Last week, at Black Hat 2024, one of the major cybersecurity events in the world, a few disconcerting revelations about the potential insecure nature of GenAI and LLM implementations came to the fore – and how they can be exploited by hackers and malicious actors to steal user data and critical business intelligence. Here are the top highlights:

Microsoft Copilot AI's potential data leak

One of the most shocking revelations to emerge from Black Hat 2024 was the vulnerability of Microsoft's AI assistant, Copilot. Security researcher Michael Bargury, CTO, Zenity, and his colleague Avishai Efrat, exposed critical security loopholes in Microsoft's Copilot Studio offering that could allow malicious actors to hack into corporate networks and access sensitive data.

Microsoft unveiled Copilot Studio back in February 2023, giving businesses the power to create their own custom AI assistants. This tool empowers them to teach these assistants how to handle specific business processes using internal data within Microsoft's suite of applications. Copilot understands everything from typed instructions to images

and even spoken commands, and it can be deployed directly onto new Windows 11 laptops and AI PCs natively. Bargury demonstrated that Copilot Studio is rife with security risks. By exploiting insecure default settings, plugins with broad permissions, and fundamental design flaws, attackers could potentially access and steal sensitive enterprise data, according to Bargury. The researcher also warned that the ease with which these vulnerabilities can be exploited makes data leakage highly probable.

Furthermore, Bargury unveiled a tool, Copilot Hunter, which is capable of scanning for publicly accessible Copilot instances and extracting valuable information. Needless to say this discovery highlights the urgent need for organisations to prioritise the security of their AI systems and implement safeguards to protect sensitive data. Incidentally, Johann Rehberger, popular cybersecurity researcher, has recently outlined a blog post on preventing data leaks in Copilot Studio.

NVIDIA AI Red Team on indirect prompt injection

The NVIDIA AI Red Team also highlighted critical vulnerabilities in large language models (LLMs) at Black Hat 2024. Among the most concerning are indirect prompt injections, where an LLM responds to manipulated input from a third-party source, and security issues related to plugins, which could be exploited to gain unauthorised access to the LLM.

